

Caso prático InterMed

Enunciado — caso base e exercícios das Sessões 1 e 2 · Ciclo do Negócio de Cibersegurança

Documento disponibilizado exclusivamente para uso dos formandos desta formação. Os restantes exercícios do caso serão publicados à medida que as sessões avançam.

1. Caso de estudo — InterMed & Digital

Contexto geral da InterMed

A InterMed é um grupo privado de saúde com hospitais, clínicas, centros de diagnóstico e serviços ambulatoriais, suportado por uma base tecnológica heterogénea, construída ao longo do tempo por aquisições, crescimento orgânico e múltiplas decisões locais de investimento em sistemas.

A nova administração assumiu recentemente funções com uma agenda clara de crescimento, eficiência operacional e transformação digital, pretendendo acelerar canais digitais, integração de dados, relacionamento com doentes, parcerias B2B e novos serviços digitais em saúde.

O novo CEO considera que a transformação digital é um vetor central da estratégia, mas entende também que a capacidade de execução da InterMed pode não estar ao nível da ambição estratégica.

Existem dúvidas sobre a maturidade interna para suportar uma agenda intensa de mudança: os processos de governação tecnológica são pouco uniformes, a arquitetura aplicacional é fragmentada, a dependência de terceiros é elevada e as equipas internas têm sinais de escassez em áreas críticas, sobretudo cibersegurança, arquitetura, gestão de serviço e gestão de fornecedores.

Neste contexto, a organização enfrenta riscos de execução estratégica relevantes. A nova estratégia digital exige que projetos de modernização, interoperabilidade, aplicações online, analytics, cloud e IA avancem com maior rapidez, mas a InterMed ainda revela um modelo organizacional tradicional, com Segurança da Informação integrada em IT, baixa integração entre áreas e fraca articulação entre risco corporativo, compliance, operações e tecnologia. A NIS2 reforça precisamente a necessidade de governação, gestão de risco, monitorização, segurança da cadeia de fornecimento, secure development e reporting ao órgão de gestão, o que torna mais visível a distância entre a ambição estratégica e a maturidade atual.

O novo CEO pediu também uma informação mais direta, executiva e acionável sobre a gestão da cibersegurança. Em vez de relatórios excessivamente técnicos, pretende receber uma visão sintética sobre exposição ao risco, dependências críticas, nível de maturidade, decisões prioritárias e impacto no negócio. Esta alteração de expectativa executiva cria uma oportunidade para reposicionar a cibersegurança como tema de gestão e de execução estratégica, e não apenas como função técnica dentro do IT.

2. Modelo estratégico CISO da InterMed (Matriz de McFarlan) — Sessão 1

A InterMed opera um conjunto alargado de sistemas de informação (SI) que suportam cuidados de saúde, back-office, relação com doentes, integração com pagadores e processos administrativos. A nova estratégia digital quer acelerar canais digitais, analytics, integração de dados clínicos e operacionais e novas propostas de valor para parceiros e doentes, mas a organização ainda não dispõe de um modelo claro para diferenciar os sistemas que apenas suportam eficiência daqueles que são críticos para operar hoje ou determinantes para competir amanhã.

Neste contexto, a administração pediu ao responsável de segurança, em articulação com IT e com o negócio, um exercício simples de leitura estratégica dos sistemas através da Matriz de McFarlan. O objetivo é perceber que sistemas são apenas de suporte, quais são operacionais e críticos para a continuidade, quais têm potencial transformador e quais já são estratégicos. Para o CISO, este exercício é útil porque ajuda a ligar criticidade, risco, prioridade de controlo, dependência de terceiros e narrativa executiva sobre investimento.

Entre os sistemas em análise estão o Dossier Clínico Eletrónico (DCE), o sistema de agendamento, a gestão de camas e bloco operatório, o ERP financeiro e de compras, o portal do doente, a app móvel, a plataforma de BI, o RH, o email, o sistema de faturação, as integrações com seguradoras, soluções cloud e serviços de suporte. A dificuldade é que a InterMed não tem ainda um modelo unificado de classificação de criticidade, nem critérios estáveis que cruzem impacto operacional, impacto clínico, receita, reputação, obrigações legais, dependência de terceiros e relevância estratégica.

Acresce que a baixa maturidade organizacional torna o exercício mais complexo e mais útil. Algumas áreas classificam sistemas apenas com base na sua importância local; outras focam-se no custo; outras ainda confundem inovação com criticidade. Não existe uma taxonomia partilhada sobre o que é «crítico», não há consenso sobre tolerância à indisponibilidade e as dependências de terceiros são pouco transparentes. A aplicação da matriz deve, por isso, ser usada também como instrumento de alinhamento entre negócio, IT, risco e cibersegurança.

Dados adicionais para análise

- O DCE suporta assistência clínica diária e integra prescrição, exames e histórico.
- O portal do doente cresceu 40% no último ano e o CEO quer duplicar a adoção digital em 18 meses.
- O sistema de faturação tem impacto direto em receita e convenções.
- O BI é visto como base para decisões de eficiência, expansão e performance.
- O ERP é importante, mas vários processos ainda conseguem fallback parcial.
- O email é relevante, mas não é elemento diferenciador do negócio.
- Vários sistemas críticos dependem de fornecedores externos e cloud.
- Não existe inventário completo de interdependências aplicacionais.

Questões

- 1 Classifique os sistemas na Matriz de McFarlan.
- 2 Justifique a posição de cada sistema com base em impacto atual e impacto futuro.
- 3 Identifique o principal risco cyber por quadrante.
- 4 Associe a cada quadrante o principal driver de decisão do CISO.
- 5 Explique como a matriz pode apoiar o reporting executivo ao CEO.

Checklist de apoio

- O sistema é crítico para operar hoje?
- O sistema é relevante para competir amanhã?
- A sua falha afeta cuidado clínico, receita ou reputação?
- Existe forte dependência de terceiros?
- Há fallback ou workaround?
- O sistema trata dados de saúde ou outros dados sensíveis?
- O sistema é alvo provável de requisitos reforçados de continuidade e monitorização?
- O sistema é visto pela administração como alavanca estratégica?
- A classificação é partilhada entre negócio, IT e segurança?

Folha de resposta

Sistema	Quadrante	Risco cyber dominante	Driver de decisão
DCE			
Agendamento			
Faturação			
ERP			
Portal do doente			
App móvel			
BI			
RH			
Email			

Nota: a resposta a este exercício entrega-se na Ficha de Trabalho S1 (disponível na página da Sessão 1).

3. Análise de maturidade — Sessão 2

A InterMed apresenta um organograma ainda tradicional, em que a Segurança está posicionada dentro de IT. A organização não demonstra ainda um modelo maduro de papéis, responsabilidades e autoridades em matéria de segurança, nem uma integração consistente entre o modelo do risco empresarial e a gestão do risco cyber, em contraciclo com o foco de governance e risk management presente nas boas práticas.

Existe um prestador externo para apoio à microinformática e suporte de utilizadores, mas a empresa não tem capacidades consolidadas de gestão de serviço: faltam processos maduros de incident management, problem management, change management, service catalogue, reporting por SLA, escalado funcional e indicadores transversais. Esta fragilidade de operação torna mais difícil obter visibilidade sobre falhas, dependências, degradação de serviços e sinais de incidente, o que enfraquece também as capacidades pedidas pela NIS2 para monitorização, logging, event reporting e incident handling.

A equipa de cibersegurança é reduzida e essencialmente reativa. Não há capacidade interna robusta para arquitetura de segurança, threat detection, governance de terceiros, secure development, testes de segurança ou reporting executivo continuado. Em paralelo, a colaboração entre áreas é limitada, com silos entre IT, operações clínicas, jurídico, compras, risco e negócio, o que dificulta a tomada de decisão coordenada e a institucionalização de uma abordagem «security by design» e «risk by design».

Sinais adicionais de baixa maturidade

- Não existe inventário consolidado e classificado de ativos e serviços críticos.
- O registo de risco corporativo não cobre de forma estruturada os principais cenários cyber.
- Não existe diretório completo e vivo de fornecedores e prestadores de serviços críticos.
- Os contratos com terceiros têm requisitos de segurança pouco uniformes.
- Não existem revisões independentes regulares de segurança nem reporting formal ao órgão de gestão.
- As mudanças tecnológicas urgentes tendem a contornar processos formais.
- A monitorização e o logging são parciais e pouco correlacionados.
- O desenvolvimento aplicacional é maioritariamente orientado por requisitos funcionais e prazos definidos pelas áreas.

Dados adicionais para análise de maturidade

- Existe política corporativa única de segurança aprovada pelo órgão de gestão.
- O comité de risco corporativo não inclui cyber como agenda permanente.
- O board recebe apenas informação reativa quando existe incidente relevante.
- Não há quadro formal de KRIs/KPIs de cyber para gestão.
- Não há processo consistente para aceitação de risco residual.
- Não existe plano anual de revisões independentes de segurança.
- A função de segurança depende de recursos escassos e fortemente operacionais.
- Não existe calendarização formal de exercícios executivos de incidente/crise.

Questões

- 1 Avalie a maturidade atual de governance & gestão cyber da InterMed numa escala de 1 a 5 e justifique.

2 Identifique as principais lacunas face à NIS2 no domínio de governance, risco e reporting executivo.

Nota: utilize a Ficha de Trabalho S2 (disponível na página da Sessão 2) como folha de resposta.

4. Comunicação ao board e requisitos de governance — Sessão 2

A nova administração da InterMed iniciou um programa de transformação digital com forte pressão sobre crescimento, eficiência e experiência do doente. Entre as prioridades estratégicas estão o reforço dos canais digitais, a modernização dos sistemas de relacionamento com o doente, o aumento da integração entre unidades, a aposta em analytics e a criação de novos serviços digitais. O CEO reconhece, contudo, que a organização pode estar a assumir riscos de execução que não domina totalmente, sobretudo porque a maturidade de governação digital e de cibersegurança ainda é baixa.

No atual organograma, a Segurança da Informação está inserida na área de IT. O risco corporativo não incorpora de forma sistemática a cibersegurança, a articulação entre equipas é fraca e não existe uma linha clara de comunicação executiva sobre risco cyber, terceiros críticos, incidentes, exposição regulatória ou impacto estratégico. O novo CEO quer alterar esta situação e pediu ao responsável de segurança uma visão mais direta, orientada à decisão, sobre o estado da cibersegurança e as prioridades dos próximos 12 meses.

Como parte deste movimento, o CEO decidiu promover um workshop executivo de duas horas com o board alargado, incluindo CEO, CFO, COO, diretor clínico, compras, jurídico/compliance e risco corporativo. O objetivo é alinhar linguagem, clarificar responsabilidades, perceber as implicações práticas da NIS2 e discutir que modelo de governance deve suportar a nova estratégia digital. O responsável de segurança vê aqui uma oportunidade para reposicionar a função, sair da lógica puramente técnica e passar a enquadrar a cibersegurança como tema de governação, resiliência e execução estratégica.

Há, no entanto, constrangimentos adicionais que agravam a análise de maturidade. A InterMed não faz reporting regular ao órgão de gestão com formato standardizado; não existem comités formais onde cyber, risco, operações e negócio decidam em conjunto; as revisões independentes de segurança são esporádicas; a gestão de exceções e de risco residual é pouco documentada; e muitas decisões sobre fornecedores, cloud ou novas aplicações são tomadas por projeto, sem uma visão transversal. À luz da NIS2, estas fragilidades mostram insuficiência em áreas como política de segurança, papéis e responsabilidades, framework de risco, compliance monitoring, independent review e reporting ao management body.

Questões

- 1 Analise a situação específica da governance e os requisitos necessários à luz da NIS2.
- 2 Estruture uma agenda para o workshop executivo.
- 3 Defina as principais mensagens executivas que o CISO deve levar ao CEO e ao board (Cyber SWOT).

Checklist de apoio

- Existe política de segurança aprovada pela gestão?
- Estão definidos papéis, responsabilidades e autoridades?
- O risco cyber integra o ERM?
- Existe reporting regular ao órgão de gestão?
- Há indicadores executivos sobre exposição, capacidade e progresso?
- Existem revisões independentes e compliance monitoring?
- Há processo de aceitação de risco residual?
- Os terceiros críticos entram na visão executiva de risco?

- Existe preparação executiva para incidentes e crises?
- O modelo atual permite escalar a estratégia digital com controlo?

Nota: utilize a Ficha de Trabalho S2 como folha de resposta. Os exercícios seguintes do caso (cadeia de valor e terceiros, avaliação de fornecedores, security by design e IA) serão publicados nas páginas das respetivas sessões.